

How to Review a New AI Agent

A repeatable security assessment methodology — from intake to Go / No-Go

Every new AI agent is a new attack surface: it reads untrusted input, holds context, calls tools, and often acts with real permissions. This playbook is the process for reviewing one **before it reaches production**. It turns an open-ended "is this safe?" into a structured pass across eight security domains, a defensible risk tier, and a clear production recommendation — the same workflow the assessment platform automates.

When to run a review

Run a full review at any of these triggers — and re-run it whenever the deployment changes, because a point-in-time review is stale the moment the agent gains a new tool or data source:

- **Before production** — any new agent, no exceptions.
- **Scope change** — a new tool, data source, integration, or permission is added.
- **Model or prompt change** — base model swap, or a material system-prompt rewrite.
- **Shadow AI discovered** — an agent found running without prior review.

Step 1 — Intake: describe the agent

You cannot assess what you have not described. Capture these five facts first; everything downstream (risk tier, framework mapping, findings) is derived from them — the reviewer states facts, the process derives the risk.

Capture	What you are recording	Why it matters
Identity & purpose	Name, owner, what it does, deployment type	Ownership + blast radius; drives the autonomy axis
Data handled	Data types + where users are located	Drives the sensitivity axis; auto-triggers regulations
Capabilities	Tools, powerful actions, code execution	Every tool is treated as semi-hostile
Identity & access	Credential type, least privilege, JIT elevation	One identity per agent; least privilege
Guardrails & ops	Human-in-the-loop, logging, kill switch, memory	Deterministic containment and monitoring posture

Step 2 — Assess across eight security domains

For each domain, ask the review question and record the control state. A "no" is a finding, not a failure — it becomes a mapped, prioritized remediation item.

Domain	The core review question
1 · LLM & Prompt	Is every injection surface defended — user input, memory, files, tool output, websites, and multimodal (image / PDF / audio carrying instructions)?

2 • RAG & Data	Are document permissions enforced, retrieval sources trusted, and cross-user leakage prevented? Can a poisoned document steer the answer?
3 • Tool & API	Is each tool least-privilege and gated? Are high-impact actions (send, delete, pay, modify) behind an approval? Treat every tool as semi-hostile.
4 • Agentic Risk	Is there a kill switch? Is memory poisoning contained? Are multi-agent and cascading-failure blast radii bounded?
5 • Adversarial ML	Has the agent been probed for jailbreaks, evasion, and model-level manipulation with multiturn and indirect attacks?
6 • Identity & Access	Does the agent have one unique identity, least privilege, JIT elevation, and a defined lifecycle across its access points?
7 • Runtime & Guardrails	Are controls deterministic (enforced in code, not by asking the model nicely)? Is a human in the loop for consequential actions?
8 • Observability & SOC	Are prompts, tool calls, and decisions logged to the SIEM? Can the SOC identify, detect, and respond to agent misuse?

Step 3 — Assign a risk tier (two axes)

Score the agent on two independent axes, then read the tier off the grid. Two axes stop a low-data / high-autonomy agent from hiding behind an average.

Data sensitivity (0–100) × Autonomy / agency (0–100) → Minimal · Limited · Elevated · Critical, mapped to EU AI Act tiers.

Tier	Roughly means	Typical posture
Minimal	Low sensitivity, low autonomy	Standard controls; light review
Limited	Some sensitivity or some autonomy	Named controls verified before launch
Elevated	Sensitive data or meaningful agency	Approvals, logging, human-in-the-loop required
Critical	High sensitivity and high autonomy	Full containment + monitoring; likely No-Go until fixed

Step 4 — The production recommendation

Verdict	Meaning
Go	No critical findings; residual risk acceptable for the tier. Ship it.
Go with conditions	Ship only after listed conditions are met (e.g. add approval gate, enable logging).
No-Go	One or more critical findings. Do not deploy until remediated and re-assessed.

Step 5 — Map once, satisfy many

Each finding is mapped through a single crosswalk to every relevant framework at once, so one review answers many obligations. Example — *"agent sends email with no approval gate"* maps to: **OWASP Agentic ASI02**, **OWASP**

LLM06, EU AI Act Art.14, NIST AI RMF (Manage), ISO/IEC 42001, and SOC 2 CC6. Report the result as *aligned with recognized frameworks as of the assessment date* — never "compliant."

Reviewer's quick checklist

- Agent described across all five intake areas (identity, data, capabilities, access, guardrails).
- Injection surfaces enumerated — including multimodal and indirect (tool / website) sources.
- Every tool inventoried; high-impact actions confirmed behind approval gates.
- Agent has one unique identity with least privilege; no shared credentials.
- Kill switch exists and is tested; blast radius is bounded.
- Prompts, tool calls, and decisions are logged to the SIEM.
- Two-axis risk tier assigned; EU AI Act tier mapped.
- Findings mapped through the crosswalk; remediation prioritized by severity.
- Go / No-Go recorded with reasons and an "assessed as of" date.
- Re-assessment scheduled / triggered on any scope change.

Safety. Reviews use safe sample data only. Never use real credentials, tokens, or customer data, and never test production systems. Any dynamic probing runs only against an explicitly authorized lab or staging environment, and results are labeled as authorized testing.